

Security Assurance Case: Najm Application

1 .System Description

Architecture: The system utilizes a Cloud-native Microservices Architecture. It connects mobile end-points (User and Investigator apps) to a central backend via secure RESTful APIs.

Integrations: It features deep integration with national platforms such as Yakeen, ELM, and SAMA (Saudi Central Bank) systems for real-time data validation.

Data Handling: Processes sensitive Personal Identifiable Information (PII), geospatial data (GPS coordinates of accidents), and financial insurance records.

2 .Threat Analysis

Adversaries: Cyber-criminals seeking financial gain, hacktivists, or individuals attempting Insurance Fraud.

Misuse Cases: * Data Exfiltration: Attempting to leak private accident photos or victim details.

- GPS Spoofing: Faking accident locations to manipulate response times or insurance claims.
- API Injection: Targeted attacks on the communication layer between the app and the traffic database.

3 .Design Rationale

Defense-in-Depth Layout: * IAM & IAM Integration: Using National Single Sign-On (Nafath) ensures that only verified citizens can access high-privilege functions.

- End-to-End Encryption (E2EE): Data is encrypted using AES-256 at rest and TLS 1.3 in transit to prevent interception.
- Application Shielding: Implementing code obfuscation and anti-tampering measures to prevent the mobile app from being reverse-engineered.

4 .V&V Results (Verification & Validation)

Penetration Testing: Regular Red Team exercises simulate real-world attacks on the cloud infrastructure to identify vulnerabilities.

NCA Compliance: The system is audited against the Essential Cybersecurity Controls (ECC) mandated by the National Cybersecurity Authority of Saudi Arabia.

Static & Dynamic Analysis: Automated tools (SAST/DAST) are integrated into the CI/CD pipeline to scan the source code for flaws before every app store release.